CCIT Report #541
July 2005

Keeping Denial-of-Service Attackers in the Dark

Gal Badishi* Amir Herzberg† Idit Keidar*

Abstract

We consider the problem of overcoming (Distributed) Denial of Service (DoS) attacks by realistic adversaries that can eavesdrop on messages, or parts thereof, but with some delay. We show a protocol that mitigates DoS attacks by eavesdropping adversaries, using only available, efficient packet filtering mechanisms based mainly on (addresses and) port numbers. Our protocol avoids the use of fixed ports, and instead performs 'pseudo-random port hopping'. We model the underlying packet-filtering services and define measures for the capabilities of the adversary and for the success rate of the protocol. Using these, we analyze the proposed protocol, and show that it provides effective DoS prevention for realistic attack and deployment scenarios.

1 Introduction

Denial of service (DoS) attacks have proliferated in recent years, causing severe service disruptions [6]. The most devastating attacks stem from *distributed denial of service (DDoS)*, where an attacker utilizes multiple machines (often thousands) to generate excessive traffic [14]. Due to the acuteness of such attacks, various commercial solutions and off-the-shelf products addressing this problem have emerged.

The most common solution uses an existing firewall/router (or protocol stack) to perform *rate-limiting* of traffic, and to *filter* messages according to header fields like address and port number. Such mechanisms are cheap and readily available, and are therefore very appealing. Nevertheless, rate-limiting indiscriminately discards messages, and it is easy to spoof (fake) headers that match the filtering criteria: an attacker can often generate spoofed packets containing correct source and destination IP addresses, and arbitrarily chosen values for almost all fields used for filtering[1]. Therefore, the only hope in using such efficient filtering mechanisms to overcome DoS attacks lies in choosing values that are *unknown to the adversary*. E.g., TCP's use of a random initial sequence number is a simple version of this approach, but is inadequate if the attacker has some (even limited) eavesdropping capability.

More effective DoS solutions are provided by expensive commercial devices that perform stateful filtering [16, 17, 18]. These solutions specialize in protecting a handful of commonly-used stateful protocols, e.g., TCP; they are less effective for stateless traffic such as UDP [18]. Such expensive solutions are not suitable for all organizations.

Finally, the most effective way to filter out offending traffic is using secure source authentication with message authentication codes (MAC), as in, e.g., IP-Sec [3]. However, this requires computing a MAC for every packet, which can induce significant overhead, and thus, this approach may be even more vulnerable to DoS attacks.

Our goal is to address DoS attacks on end hosts, e.g., in corporate networks, assuming the network leading to the hosts is functional. (A complementary solution protecting the end network can be deployed at the ISP.) In this paper, we focus on fortifying the basic building block of two-party communication. Specifically, we develop a DoS-resistant datagram protocol, similar to UDP or raw IP. Our protocol has promising properties, especially in overcoming realistic attack scenarios where attackers can discover some of the control information included in

[1]Department of Electrical Engineering, The Technion – Israel Institute of Technology.

[2]Department of Computer Science, Bar Ilan University.

[1]An exception is the TTL field of IP packets, which is automatically decremented by each router. This is used by some filtering mechanisms, e.g. BGP routers that receive only packets with maximal TTL value (255) to ensure the packets were sent by a neighboring router, and the Hop Counter Filtering proposal.